

A one-time code in front of the readmissions report

What was built, how it behaves on every path, what it protects against, and what production needs before deploy. Written for Chayim after the sandbox test.

The email no longer carries anything that opens the report. It carries a link to a page we own; that page emails a six-digit code to the address on file, and the report opens only after the code is entered. Built and live-tested in the sandbox on 15 September 2026.

- **You asked for the stronger option**, a code that expires after 10 minutes. It cannot live in the report email because the job sends at 8am and people open hours later, so the page asks for the code at view time instead.
- **A forwarded email is now covered**. The code goes to the original address, so someone holding a forwarded link cannot get in unless they also control that mailbox.
- **Nothing in production yet**. What production needs is listed at the end, two items for a Lumina admin. Deploy happens after your go-ahead.

BACKGROUND	THE DECISION	STATUS
Phase one shipped an expiring public file link, one per recipient, with an audit trail. Chris wanted the report protected by more than a URL.	A one-time code, requested on the page and emailed to the address on file, valid for 10 minutes. The public file link is removed.	Built. 142 automated tests green. Every path below was exercised by hand in the sandbox with no Salesforce login. Not yet deployed to production.

What the code protects, and how

A link is a bearer token: whoever holds it is in. The code adds a second thing to hold, and that second thing is only ever delivered to the mailbox on file. This is the difference from the earlier idea of a PIN printed in the same email, which protected the link but not a forwarded message.

CONCERN	PHASE ONE	NOW
Someone guesses another facility's URL Chris's stated worry	Already covered	The link is 64 random characters, and there is no public file URL to guess at all. Wrong, expired and closed links all get the same page.
The URL leaks on its own browser history, a pasted chat message, a screenshot, a proxy log	Opens the report	Opens a request button and nothing else. A fresh code has to reach the mailbox on file.
Someone tries codes until one works	Not applicable	Five wrong codes lock the link for good. A code lasts 10 minutes and has a million possibilities.
The whole email is forwarded	Opens the report	The code still goes to the original address. The forwarder is stuck at the request screen.
The recipient's mailbox is compromised	Opens the report	Still opens. Whoever controls the mailbox can request the code. No email-based delivery can close this one; it is the facility's mailbox security.

The change, in one line

The public file link goes away. That is what makes the code real rather than decorative. If we had kept the file link and put a code page in front of it, the file link would still work for anyone who had it.

STEP	PHASE ONE	NOW
What the email carries	A link that opens the report immediately	A link to our page, a count of admissions, and the instruction to choose <i>Email me a code</i> . No code, no patient data.
What the link points at	Salesforce's own public file viewer	A page we control, on a Salesforce Site. The only door.
What unlocks the report	Holding the URL	A six-digit code emailed to the address on file when the reader asks for it. It works for 10 minutes, and the report then stays open for 10 minutes.
Who serves the PDF	Salesforce, to anyone with the URL	Our page, only inside the 10 minutes after a correct code.
The ten-view cap	Applied by the nightly job, so a burst could overshoot	Applied at the moment of the tenth correct code. The eleventh is refused.
Who counts the opens	Salesforce's own tracking, read back by us	Our page, as it happens. A correct code is one open.
Resending	New link, old one keeps working until it expires	New link, and the previous live link to that person is closed at once.

How it behaves, path by path

Pick a scenario. The left column is the real check order in the code, the right is the recipient's screen and the record we keep for the audit trail. Every value shown is a real field on `Readmission_Report_Link__c`.

1. Find the report from the link The page hashes the token from the URL and looks for exactly one matching row.	
↓	
2. Is it still live? Past its 24 hours, locked, superseded, or at the view cap: stop here with the generic page.	
↓	
3. Email a code Six digits, to the address the link was issued to, valid 10 minutes. Not again within 60 seconds. Five per link, then locked.	
↓	
4. Check the code Compared against a stored hash, never a stored code. Wrong is a strike, expired is not. Five strikes lock the link.	
↓	
5. Record the open and unlock One open is written, the code is cleared, and the report is unlocked for 10 minutes. The tenth open closes the link.	
↓	
6. Serve the report Our page streams the PDF while the window is open. No second link exists for it.	

REMISSION REPORT LINK · RRL-00000042	
Recipient_Email__c	a***@samplecare.com
Opens__c	0
Downloads__c	0
Codes_Sent__c	0
Failed_Attempts__c	0
Unlocked_Until__c	none
Closed_Reason__c	none
Expires_At__c	16 Sep 08:00

SCENARIO	WHAT HAPPENS	WHAT THE RECORD SHOWS
Correct code	Token matches, link is live, the reader asks for a code, enters it, and it matches. The open is written, the code is cleared, and the PDF renders in the browser for 10 minutes. Reloading inside that window shows it again without a new code.	Opens__c 1, Codes_Sent__c 1, Unlocked_Until__c set, first-opened timestamp set
Downloads the PDF	Same as above, then Download PDF is pressed. Counted separately, because reading on screen and taking a copy are different disclosures.	Opens__c 1, Downloads__c 1
Asks again too soon	A second Email me a code inside 60 seconds is refused with "A code was sent less than a minute ago." No second email, no change to the record.	Codes_Sent__c 1, unchanged
Code past 10 minutes	The page says "That code has expired. Ask for a new one." No strike is counted.	Failed_Attempts__c 0, unchanged
Wrong code, five times	Each wrong attempt is counted and the page says how many are left. The fifth locks the link for good and shows the generic page. Lumina can reissue.	Failed_Attempts__c 5, Closed_Reason__c Locked
Link past 24 hours	Stops at the second check with the generic page. No code is sent, no attempt is recorded.	Unchanged, already expired
Eleventh code	A link already at 10 opens: the next correct code is refused and the link closes in that moment.	Opens__c 10, Closed_Reason__c View limit reached
Guessed URL	No row matches. The page says exactly what it says for an expired link, so a guesser learns nothing from the difference.	No record is touched
Reissued link	The Resend button, or the next morning's job, mints a new link for the same person. The previous live link is closed at once; only the newest works.	Old row Closed_Reason__c Superseded, new row live

The real screens, from the sandbox test

Captured on 15 September 2026 in a browser with no Salesforce session, in the order a reader meets them. The facility and the patient row are test data. The address shown is the tester address, masked by the page itself. The header is Lumina's own.

--	--

The request screen. What the link opens. Facility name, report date, when the link expires, the masked address the code will go to, and one button. Nothing from the report.

After Email me a code. The page confirms where the code went, offers the six-digit box, and a link to send another. A wrong code shows how many attempts are left.

--

After a correct code. The PDF inline, the two buttons, and the time the view stays open until. After that the reader asks for a new code.

What we kept, and what is new

The delivery step was the only part replaced. Everything built and tested in phase one stays.

PIECE	STATUS	WHY
The PDF itself and how it is generated	Kept	Unchanged. Still one file per facility per day, filed on the facility record.
One link per recipient, and the audit trail behind it	Kept	This is what makes an open attributable to a person. It is now more accurate, because our own page records it at the moment of disclosure.
Resend button on the facility record	Kept	Reissues a new link and closes the old one as superseded. No change to the button itself.
The daily digest to Kevin	Kept	Now counts locked links, so a facility failing to get in is visible the next morning.
Deleting the stored report once every link is dead	Kept	Same 7 day grace. A file is deleted only when no live link points at it.
Salesforce's public file link	Removed	It was the open door. Removing it is what makes the code meaningful.
A page on a Salesforce Site, and a locked-down guest profile	New	One page, one purpose. The guest holds no record or field permission at all; our code reaches the link row and the file, and only by the link's fingerprint. It cannot see a facility, a patient or an admission.
Link and code stored as fingerprints	New	We never store the link or the code itself, so reading our database does not let anyone in.
An access log on every link	New	Every step on a link, from the code being sent to the report being opened or downloaded, is logged with the time, the IP address and the browser, so a disclosure can be traced to a device as well as to a mailbox.

For the compliance conversation: this narrows the surface rather than widening it. The page that queries patient data stays inside Salesforce, run by the job. The public page only ever hands over a file that was already produced, and only inside the minutes after a code that reached the mailbox on file.

Answers to the questions that came up in the thread

QUESTION	ANSWER
Would a Salesforce external site be secure?	Yes, as long as the guest profile stays as narrow as it is now: two pages and the classes behind them, no objects, no fields. That is the whole surface, and it is written down in the technical page for sign-off.
Do they need a licence per facility?	No. Everyone arrives as the same guest user, which is included. No per-facility cost, no logins to hand out, nothing for 326 facilities to forget.
Is there already a password field on the facility record?	We do not need one. A stored password per facility would need a reset flow, a place to keep it and a rule for who may see it. A code per view avoids all three.
PIN or password?	Neither is stored or remembered. A fresh six-digit code each time, sent to the address on file when the reader asks.
Five-minute expiry, and request a new one?	Yes, with 10 minutes rather than five, so a slow inbox does not cost the reader a second round. The reader asks for the code on the page, which is why it can be short: it is issued when they are sitting in front of it, not at 8am.
Does it follow the same rules for who gets it?	Yes, unchanged. Administrator if there is one, director of nursing if not, nobody if neither, and the digest names the facilities it skipped.

What production needs

Nothing here is a build task. Two steps are for a Lumina admin, the rest are on us at deploy time.

#	NEEDED	FROM
01	Register Salesforce Sites once in production. Setup, then Sites, accept the terms, then Register My Salesforce Site Domain. The domain <code>data-efficiency-9627.my.salesforce-sites.com</code> already exists. Until this is done every page shows a maintenance notice.	Lumina admin
02	Allow the sender address. The org-wide address <code>tcmluminacare.com</code> should be allowed for all profiles, or for the site guest profile, so the code email comes from it. Otherwise the code email is sent as the site user, which works but reads worse.	Lumina admin
03	Point the site at the production domain before deploy, and assign the guest permission set once the site exists. Production links will read <code>https://data-efficiency-9627.my.salesforce-sites.com/report?t=...</code>	Propela
04	Deploy, by a person, after your go-ahead. We prepare the files and the exact command.	Propela, after Chayim
05	An owner for the missing contacts. 159 of 326 enrolled facilities still have neither an administrator nor a director-of-nursing email, mostly GHC and Complete Care. No delivery method fixes that.	Lumina